



WSTG - v4.1

Testing Tools Resource

General Testing

- [OWASP ZAP](#)
 - The Zed Attack Proxy (ZAP) is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications. It is designed to be used by people with a wide range of security experience and as such is ideal for developers and functional testers who are new to penetration testing.
 - ZAP provides automated scanners as well as a set of tools that allow you to find security vulnerabilities manually.
- [Burp Proxy](#)
 - Burp Proxy is an intercepting proxy server for security testing of web applications it allows Intercepting and modifying all HTTP(S) traffic passing in both directions, it can work with custom SSL certificates and non-proxy-aware clients.
- [Webstretch Proxy](#)
 - Webstretch Proxy enable users to view and alter all aspects of communications with a web site via a proxy. It can also be used for debugging during development.
- [Firefox HTTP Header Live](#)
 - View HTTP headers of a page and while browsing.
- [Firefox Tamper Data](#)
 - Use tamperdata to view and modify HTTP/HTTPS headers and post parameters
- [Firefox Web Developer Tools](#)
 - The Web Developer extension adds various web developer tools to the browser.
- [DOM Inspector](#)
 - DOM Inspector is a developer tool used to inspect, browse, and edit the Document Object Model (DOM)
- [Grendel-Scan](#)
 - Grendel-Scan is an automated security scanning of web applications and also supports manual penetration testing.
 - SWFItruder (pronounced Swiff Intruder) is the first tool specifically developed for analyzing and testing security of Flash applications at runtime.
- [w3af](#)
 - w3af is a Web Application Attack and Audit Framework. The project's goal is finding and exploiting web application vulnerabilities.
- [skipfish](#)
 - Skipfish is an active web application security reconnaissance tool.
- [Web Developer toolbar](#)
 - The Web Developer extension adds a toolbar button to the browser with various web developer tools. This is the official port of the Web Developer extension for Firefox.
- [HTTP Request Maker](#)
 - Request Maker is a tool for penetration testing. With it you can easily capture requests made by web pages, tamper with the URL, headers and POST data and, of course, make new requests
- [Cookie Editor](#)
 - Edit This Cookie is a cookie manager. You can add, delete, edit, search, protect and block cookies
- [Cookie swap](#)
 - Swap My Cookies is a session manager, it manages cookies, letting you login on any website with several different accounts.
- [Session Manager](#)
 - With Session Manager you can quickly save your current browser state and reload it whenever necessary. You can manage multiple sessions, rename or remove them from the session library. Each session remembers the state of the browser at its creation time, i.e the opened tabs and windows.
- [Subgraph Vega](#)
 - Vega is a free and open source scanner and testing platform to test the security of web applications. Vega can help you find and validate SQL Injection, Cross-Site Scripting (XSS), inadvertently disclosed sensitive information, and other vulnerabilities. It is written in Java, GUI based, and runs on Linux, OS X, and Windows.

WatchStar

The OWASP® Foundation works to improve the security of software through its community-led open source software projects, hundreds of chapters worldwide, tens of thousands of members, and by hosting local and global conferences.

WSTG Contents (v4.1)

- 0. Foreword by Eoin Keary
- 1. Frontispiece
- 2. Introduction
 - 2.1 The OWASP Testing Project
 - 2.2 Principles of Testing
 - 2.3 Testing Techniques Explained
 - 2.4 Manual Inspections and Reviews
 - 2.5 Threat Modeling
 - 2.6 Source Code Review
 - 2.7 Penetration Testing
 - 2.8 The Need for a Balanced Approach
 - 2.9 Deriving Security Test Requirements
 - 2.10 Security Tests Integrated in Development and Testing Workflows
 - 2.11 Security Test Data Analysis and Reporting
- 3. The OWASP Testing Framework
 - 3.1 The Web Security Testing Framework
 - 3.2 Phase 1 Before Development Begins
 - 3.3 Phase 2 During Definition and Design
 - 3.4 Phase 3 During Development
 - 3.5 Phase 4 During Deployment
 - 3.6 Phase 5 During Maintenance and Operations
 - 3.7 A Typical SDLC Testing Workflow
 - 3.8 Penetration Testing Methodologies
- 4. Web Application Security Testing
 - 4.0 Introduction and Objectives
 - 4.1 Information Gathering
 - 4.1.1 Conduct Search Engine Discovery
 - 4.1.2 Fingerprint Web Server
 - 4.1.3 Review Webserver Metafiles for Information Leakage
 - 4.1.4 Enumerate Applications on Webserver
 - 4.1.5 Review Webpage Comments and Metadata for Information Leakage
 - 4.1.6 Identify Application Entry Points
 - 4.1.7 Map Execution Paths Through Application
 - 4.1.8 Fingerprint Web Application Framework
 - 4.1.9 Fingerprint Web Application
 - 4.1.10 Map Application Architecture
 - 4.2 Configuration and Deployment Management Testing
 - 4.2.1 Test Network Infrastructure Configuration
 - 4.2.2 Test Application Platform Configuration
 - 4.2.3 Test File Extensions Handling for Sensitive Information
 - 4.2.4 Review Old Backup and Unreferenced Files for Sensitive Information
 - 4.2.5 Enumerate Infrastructure and Application Admin Interfaces
 - 4.2.6 Test HTTP Methods
 - 4.2.7 Test HTTP Strict Transport Security
 - 4.2.8 Test RIA Cross Domain Policy
 - 4.2.9 Test File Permission
 - 4.2.10 Test Session Hijacking
 - 4.2.11 Test Cloud Storage

Testing for JavaScript Security, DOM XSS

- [BlueClosure BC Detect](#)

Testing for SQL Injection

- [SqlNinja: a SQL Server Injection & Takeover Tool](#)
- [Bernardo Damele A. G.: sqlmap, automatic SQL injection tool](#)
- [Absinthe 1.1 \(formerly SQLSqueal\)](#)
- [SQLInjector - Uses inference techniques to extract data and determine the backend database server](#)
- [Bsqlbf-v2: A perl script allows extraction of data from Blind SQL Injections](#)
- [Pangolin: An automatic SQL injection penetration testing tool](#)
- [Multiple DBMS Sql Injection tool - SQL Power Injector](#)

Testing Oracle

- [Toad for Oracle](#)

Testing SSL

- [O-Saft](#)
- [sslyze](#)
- [TestSSLServer](#)
- [SSLScan](#)
- [SSLScan windows](#)
- [SSLLabs](#)

Testing for Brute Force Password

- [THC Hydra](#)
- [John the Ripper](#)
- [Medusa](#)
- [Ncat](#)
- [HashCat](#)
- [fgdump](#)
- [Password Dictionary](#)

Testing Buffer Overflow

- [OllyDbg](#)
 - “A windows based debugger used for analyzing buffer overflow vulnerabilities”
- [Spike](#)
 - A fuzzer framework that can be used to explore vulnerabilities and perform length testing
- [Brute Force Binary Tester \(BFB\)](#)
 - A proactive binary checker
- [Metasploit](#)
 - A rapid exploit development and Testing frame work

Fuzzer

- [Wfuzz](#)

Googling

- [Bishop Fox's Google Hacking Diggity Project](#)
- [Google Hacking database](#)

Slow HTTP

- [Slowloris](#)
- [slowhttptest](#)

Commercial Black-Box Testing Tools

- [NGS Typhon](#)
- [IBM AppScan](#)
- [Burp Intruder](#)
- [Acunetix Web Vulnerability Scanner](#)
- [MaxPatrol Security Scanner](#)
- [Parasoft SOAtest \(more QA-type tool\)](#)
- [N-Stalker Web Application Security Scanner](#)
- [SoapUI \(Web Service security testing\)](#)

4.3 Identity Management Testing

4.3.1 Test Role Definitions

4.3.2 Test User Registration Process

4.3.3 Test Account Provisioning Process

4.3.4 Testing for Account Enumeration and Guessable User Account

4.3.5 Testing for Weak or Unenforced Username Policy

4.4 Authentication Testing

4.4.1 Testing for Credentials Transported over an Encrypted Channel

4.4.2 Testing for Default Credentials

4.4.3 Testing for Weak Lock Out Mechanism

4.4.4 Testing for Bypassing Authentication Schema

4.4.5 Testing for Vulnerable Remember Password

4.4.6 Testing for Browser Cache Weaknesses

4.4.7 Testing for Weak Password Policy

4.4.8 Testing for Weak Security Question Answer

4.4.9 Testing for Weak Password Change or Reset Functionalities

4.4.10 Testing for Weaker Authentication in Alternative Channel

4.5 Authorization Testing

4.5.1 Testing Directory Traversal File Include

4.5.2 Testing for Bypassing Authorization Schema

4.5.3 Testing for Privilege Escalation

4.5.4 Testing for Insecure Direct Object References

4.6 Session Management Testing

4.6.1 Testing for Session Management Schema

4.6.2 Testing for Cookies Attributes

4.6.3 Testing for Session Fixation

4.6.4 Testing for Exposed Session Variables

4.6.5 Testing for Cross Site Request Forgery

4.6.6 Testing for Logout Functionality

4.6.7 Testing Session Timeout

4.6.8 Testing for Session Puzzling

4.7 Input Validation Testing

4.7.1 Testing for Reflected Cross Site Scripting

4.7.2 Testing for Stored Cross Site Scripting

4.7.3 Testing for HTTP Verb Tampering

4.7.4 Testing for HTTP Parameter Pollution

4.7.5 Testing for SQL Injection

4.7.5.1 Testing for Oracle

4.7.5.2 Testing for MySQL

4.7.5.3 Testing for SQL Server

4.7.5.4 Testing PostgreSQL

4.7.5.5 Testing for MS Access

4.7.5.6 Testing for NoSQL Injection

4.7.5.7 Testing for ORM Injection

4.7.5.8 Testing for Client Side

4.7.6 Testing for LDAP Injection

4.7.7 Testing for XML Injection

4.7.8 Testing for SSI Injection

4.7.9 Testing for XPath Injection

4.7.10 Testing for IMAP SMTP Injection

4.7.11 Testing for Code Injection

4.7.11.1 Testing for Local File Inclusion

4.7.11.2 Testing for Remote File Inclusion

4.7.12 Testing for Command Injection

4.7.13 Testing for Buffer Overflow

4.7.13.1 Testing for Heap Overflow

4.7.13.2 Testing for Stack Overflow

4.7.13.3 Testing for Format String

4.7.14 Testing for Incubated Vulnerability

4.7.15 Testing for HTTP Splitting Smuggling

4.7.16 Testing for HTTP Incoming Requests

4.7.17 Testing for Host Header Injection

4.7.18 Testing for Server Side Template Injection

- [Netsparker](#)
- [SAINT](#)
- [QualysGuard WAS](#)
- [IndusGuard Web](#)

Linux Distrubtion

- [PenTestBox](#)
- [Samurai](#)
- [Santoku](#)
- [ParrotSecurity](#)
- [Kali](#)
- [Matriux](#)
- [BlackArch](#)
- [PenToo](#)

Source Code Analyzers

Open Source / Freeware

- [Spotbugs](#)
- [Find Security Bugs](#)
- [FlawFinder](#)
- [phpcs-security-audit](#)
- [PMD](#)
- [Microsoft's FxCop](#)
- [Oedipus](#)
- [Splint](#)
- [SonarQube](#)
- [W3af](#)

Commercial

- [Checkmarx CxSuite](#)
- [GrammarTech](#)
- [ITS4](#)
- [ParaSoft](#)
- [Virtual Forge CodeProfiler for ABAP](#)
- [Veracode](#)
- [Peach Fuzzer](#)
- [Burp Suite](#)

Acceptance Testing Tools

Acceptance testing tools are used to validate the functionality of web applications. Some follow a scripted approach and typically make use of a Unit Testing framework to construct test suites and test cases. Most, if not all, can be adapted to perform security specific tests in addition to functional tests.

- [BDD Security](#)

Open Source Tools

- [HtmlUnit](#)
 - A Java and JUnit based framework that uses the Apache HttpClient as the transport.
 - Very robust and configurable and is used as the engine for a number of other testing tools.
- [jWebUnit](#)
 - A Java based meta-framework that uses htmlunit or selenium as the testing engine.
- [HttpUnit](#)
 - One of the first web testing frameworks, suffers from using the native JDK provided HTTP transport, which can be a bit limiting for security testing.
- [Solex](#)
 - An Eclipse plugin that provides a graphical tool to record HTTP sessions and make assertions based on the results.
- [Selenium](#)
 - JavaScript based testing framework, cross-platform and provides a GUI for creating tests.
 - Mature and popular tool, but the use of JavaScript could hamper certain security tests.

Other Tools

Binary Analysis

- 4.8 Testing for Error Handling
 - 4.8.1 Testing for Error Code
 - 4.8.2 Testing for Stack Traces
- 4.9 Testing for Weak Cryptography
 - 4.9.1 Testing for Weak SSL TLS Ciphers Insufficient Transport Layer Protection
 - 4.9.2 Testing for Padding Oracle
 - 4.9.3 Testing for Sensitive Information Sent via Unencrypted Channels
 - 4.9.4 Testing for Weak Encryption
- 4.10 Business Logic Testing
 - 4.10.0 Introduction to Business Logic
 - 4.10.1 Test Business Logic Data Validation
 - 4.10.2 Test Ability to Forge Requests
 - 4.10.3 Test Integrity Checks
 - 4.10.4 Test for Process Timing
 - 4.10.5 Test Number of Times a Function Can Be Used Limits
 - 4.10.6 Testing for the Circumvention of Work Flows
 - 4.10.7 Test Defenses Against Application Misuse
 - 4.10.8 Test Upload of Unexpected File Types
 - 4.10.9 Test Upload of Malicious Files
- 4.11 Client Side Testing
 - 4.11.1 Testing for DOM-Based Cross Site Scripting
 - 4.11.2 Testing for JavaScript Execution
 - 4.11.3 Testing for HTML Injection
 - 4.11.4 Testing for Client Side URL Redirect
 - 4.11.5 Testing for CSS Injection
 - 4.11.6 Testing for Client Side Resource Manipulation
 - 4.11.7 Testing Cross Origin Resource Sharing
 - 4.11.8 Testing for Cross Site Flashing
 - 4.11.9 Testing for Clickjacking
 - 4.11.10 Testing WebSockets
 - 4.11.11 Testing Web Messaging
 - 4.11.12 Testing Browser Storage
 - 4.11.13 Testing for Cross Site Script Inclusion
- 5. Reporting
- Appendix A. Testing Tools Resource
- Appendix B. Suggested Reading
- Appendix C. Fuzz Vectors
- Appendix D. Encoded Injection
- Appendix E. History

Upcoming OWASP Global Events

- OWASP Global AppSec EU 2026 - Vienna, Austria
 - June 22-26, 2026
- OWASP Global AppSec USA 2026 - San Francisco, CA
 - November 2-6, 2026
- OWASP Global AppSec EU 2027 - Vienna, Austria
 - June 21-25, 2027
- OWASP Global AppSec USA 2027 - Atlanta, GA
 - September 20-24, 2027
- OWASP Global AppSec EU 2028 - Vienna, Austria
 - June 19-23, 2028

- [BugScam IDC Package](#)
- [Veracode](#)

Site Mirroring

- [wget](#)
- [Wget for windows](#)
- [curl](#)
- [Xenu's Link Sleuth](#)

[Edit on GitHub](#)

Spotlight: Hitachi Systems, Ltd.

HITACHI Inspire the Next

Hitachi Systems is committed to promoting sustainability management and supporting social innovation initiatives within the Hitachi Group to achieve the goal of contributing to the realization of a truly affluent society. Through our ability to solve real-world problems in various industries, we have built up a vast service infrastructure and well-trained human resources that have a solid understanding of our customers' business requirements. This can be utilized to provide a range of digitalization services and comprehensive support for our customers' digital transformations by offering Hitachi's Lumada which utilizes advanced digital technology as well as unique services in collaboration with our partners.

Corporate Supporters



[Become a corporate supporter](#)

[PRIVACY](#) [SITEMAP](#) [CONTACT](#)



OWASP, the OWASP logo, and Global AppSec are registered trademarks and AppSec Days, AppSec California, AppSec Cali, SnowFROC, OWASP Boston Application Security Conference, and LASCON are trademarks of the OWASP Foundation, Inc. Unless otherwise specified, all content on the site is Creative Commons Attribution-ShareAlike v4.0 and provided without warranty of service or accuracy. For more information, please refer to our [General Disclaimer](#). OWASP does not endorse or recommend commercial products or services, allowing our community to remain vendor neutral with the collective wisdom of the best minds in software security worldwide. Copyright 2026, OWASP Foundation, Inc.